



Chapter 2: Malware

CompTIA Security+ Study Slides

Walailak University — Assist. Prof. Dr. CJ

Learning Objectives

- Define malware and classify major malware families
- Describe common infection and delivery vectors
- Explain detection, containment, and removal strategies
- Review case studies and historical incidents for context
- Propose lab exercises to practice analysis and defenses

What is Malware?

Definition:

Malware (malicious software) is any software intentionally designed to cause damage, steal data, or otherwise perform undesirable actions on a computing system.

Primary motivations:

- Financial gain
- Espionage / intelligence gathering
- Sabotage / disruption
- Political or social objectives

Taxonomy: Major Malware Types

- **Virus** — attaches to executable content; requires user action to propagate
- **Worm** — self-replicating; propagates across networks without user action
- **Trojan Horse** — appears benign but contains malicious payloads (e.g., RAT)
- **Ransomware** — encrypts data or denies access until ransom paid
- **Spyware / Adware** — collects information or displays unwanted advertising
- **Rootkit** — hides presence and provides persistent, privileged control
- **Logic Bomb** — payload triggers under specific conditions/time
- **Botnet / Zombie** — compromised hosts under centralized or distributed control
- **Fileless Malware** — operates in memory or leverages legitimate processes

Viruses: Key Characteristics

- Require execution by user or host process
- Often attach to files, documents (macro), or boot sectors
- Types: boot-sector, macro, program, multipartite, polymorphic, metamorphic
- Defensive note: macro-enabled documents and removable media are frequent vectors

Worms: Key Characteristics

- Self-replicating and network-aware
- Exploit vulnerabilities or misconfigurations to propagate (e.g., SMB, RDP)
- High potential for rapid widespread impact (e.g., mass scanning, bandwidth consumption)
- Defence: patching, network segmentation, firewalling, IPS/IDS

Trojans & RATs

- Disguised as legitimate software or bundled with it
- Common payloads: backdoor, keylogger, credential harvester, data exfiltration
- **Remote Access Trojan (RAT):** provides persistent remote control to attacker
- Defence: restrict execution privileges, application whitelisting, endpoint detection

Ransomware: Anatomy

1. Initial access (phishing, RDP compromise, exploit)
2. Lateral movement and privilege escalation
3. Discovery and encryption of high-value data
4. Extortion (ransom note, data leak threats)

Controls: backups (offline/immutable), segmentation, EDR, offline recovery plans

Spyware, Adware, and PUPs

- Spyware silently collects user or system data (keystrokes, browsing history)
- Adware displays intrusive advertisements and may degrade performance
- Potentially Unwanted Programs (PUPs) often bundled with free software
- Controls: least privilege, EDR/anti-malware, user education, software supply controls

● Rootkits and Persistence

- Rootkits modify OS/kernel or use stealth techniques (DLL injection, driver manipulation)
- Hard to detect; often require forensic imaging or reimaging to remove
- Use secure boot, signed drivers, and minimize privileged code paths

Fileless Malware and Living-off-the-Land

- Resides in memory, leverages legitimate admin tools (PowerShell, WMI, certutil)
- Detection requires behavioral monitoring and memory forensics
- Mitigation: restrict scripting, application control, EDR with process behavior analytics

Malware Delivery Vectors

- Phishing emails with malicious attachments or links
- Drive-by downloads and compromised websites (watering hole)
- Removable media (USB) and social engineering
- Exploited public-facing services (RDP, VPN, web apps)
- Third-party software supply chain compromise

Indicators of Compromise (IoCs)

- Unusual outbound network connections to external IPs
- Unexpected processes running with high privileges
- New or modified scheduled tasks / services / autoruns
- Abnormal file encryption activity or mass file modification
- Significant increases in CPU/IO or anomalous user behavior



Detection Techniques

- Signature-based scanning (AV/anti-malware)
- Heuristic and machine-learning detection for unknown threats
- Behavioral and anomaly detection (EDR, NIDS, HIPS)
- Memory analysis and sandboxing (dynamic analysis)
- Threat intelligence feeds for IoC enrichment



Incident Response: Contain, Eradicate, Recover

1. **Identification:** confirm and scope the incident
2. **Containment:** isolate affected hosts, block C2 channels
3. **Eradication:** remove malware (quarantine, reimage, patch)
4. **Recovery:** restore from clean backups, validate integrity
5. **Post-Incident:** root cause analysis, lessons learned, update controls

Removal & Remediation Best Practices

- Preserve volatile evidence (memory, logs) before remediation
- Quarantine infected endpoints; avoid reconnecting to the network
- Disable System Restore (Windows) when performing cleanup (if needed)
- Reimage when rootkit or persistent compromise suspected
- Rotate credentials and secrets exposed during compromise

Preventive Controls & Hardening

- Patch management and vulnerability remediation
- Principle of least privilege; role-based access control
- Multi-factor authentication (MFA) for all remote access
- Network segmentation and micro-segmentation for critical resources
- Backups: offline, immutable snapshots, test restoration procedures

Case Studies (historical examples)

- **WannaCry (2017):** worm-like ransomware exploiting SMB EternalBlue; criticality of patching and segmentation
- **Conficker (2008):** large-scale worm leveraging Windows vulnerabilities; highlights botnet formation
- **NotPetya (2017):** destructive wiper masquerading as ransomware; supply chain and update mechanism impact

Lab Exercises (practical)

- Analyze a captured malware sample in an isolated VM/sandbox (static + dynamic)
- Simulate phishing campaign and measure user susceptibility (consent-based)
- Configure EDR to detect a living-off-the-land PowerShell attack
- Set up backups and perform a measured restore after simulated ransomware encryption



Recommended Reading & Tools

- Static analysis: `strings`, `PEiD`, `Ghidra` (offline, safe environment)
- Dynamic analysis: Cuckoo Sandbox, VirtualBox/VMware with network sinkhole
- Forensics: Volatility (memory), Autopsy (disk)
- Detection/Prevention: EDR platforms, IDS/IPS, SIEM for correlation

Summary

- Malware is diverse: understand families, vectors, and objectives
- Defense is layered: prevention, detection, response, and recovery
- Emphasize secure configuration, patching, least privilege, and backups
- Practical labs enhance understanding and build defensive skills

End of Chapter 2

Next: [Chapter 3 — Security Applications & Devices](#)